

이메일 보안 정책 가이드라인

이 문서는 회사 내부 직원들이 이메일 작성 시 반드시 준수해야 하는 보안 정책과 모범 사례를 상세히 설명합니다. 이메일을 통한 민감 정보 유출, 악성코드 전파, 피싱 공격 등 다양한 보안 위협으로부터 조직과 고객을 보호하기 위해 작성되었습니다.

1. 이메일 보안의 중요성

이메일은 회사 내외부 커뮤니케이션에서 가장 많이 사용되는 수단으로, 민감한 정보가 포함될 가능성이 높습니다. 잘못된 이메일 관리 및 작성으로 인해 정보 유출, 금전적 피해, 기업 평판 손상 등의 심각한 사고가 발생할 수 있습니다. 따라서 모든 직원은 이메일 보안 정책을 철저히 준수해야 하며, 특히 다음과 같은 사항에 주의해야 합니다.

2. 민감 정보 처리 지침

이메일 본문, 첨부파일, 링크 등 모든 내용에 대해 민감 정보가 포함되었는지 반드시 확인해야 합니다. 민감 정보는 개인 식별 정보(PII), 신용카드 번호, 비밀번호, 내부 회계자료 등 기밀로 분류된 데이터를 의미합니다.

- 주민등록번호, 여권번호 등 개인 신분정보는 이메일로 전송하지 않습니다.
- API 키, 비밀번호 등 인증정보는 절대 이메일에 포함시키지 않습니다.
- 내부 기밀자료는 반드시 암호화하여 전송하거나 보안이 강화된 내부 시스템을 사용합니다.
- 민감 정보가 포함된 이메일은 수신자가 정확한지 재차 확인합니다.
- 외부 이메일 수신 시 보안 등급에 따라 별도 검토 절차를 거칩니다.

3. 이메일 작성 시 주의사항

이메일 작성 시 다음의 보안 모범 사례를 준수해야 합니다.

- 민감 정보는 본문 대신 안전한 링크나 내부 포털을 통해 공유합니다.
- 첨부파일은 바이러스 검사를 실시한 후 발송하며, 실행 파일(.exe) 등 위험 파일 첨부을 금지합니다.
- 수신자 목록은 필요한 최소한으로 제한하고, 다수에게 발송 시 '숨은 참조(Bcc)' 기능을 사용합니다.
- 메일 제목과 본문에 과도한 강조나 과장된 내용은 피하여 피싱 메일로 오인받지 않도록 합니다.
- 의심스러운 메일 답장이나 전달을 피하고, 출처가 불분명한 링크는 클릭하지 않습니다.

4. 피싱 및 악성코드 대응

이메일을 통한 피싱 공격 및 악성코드 유포는 가장 빈번한 보안 위협 중 하나입니다. 다음과 같은 대응 지침을 숙지하고 항상 경계해야 합니다.

- 발신자 주소와 도메인을 반드시 확인하여 정상 발신자인지 확인합니다.
- 예상치 못한 첨부파일이나 링크는 클릭하지 않고 보안팀에 즉시 보고합니다.
- 비밀번호 변경 요청이나 금융정보 요구 메일은 반드시 공식 경로를 통해 재확인합니다.
- 공격 의심 메일 발견 시 즉시 삭제하고, 조직 내 보안 담당자에게 신고합니다.
- 정기적인 보안 교육과 모의 피싱 훈련에 적극 참여합니다.

5. 이메일 보안 도구 활용

회사에서는 다음과 같은 보안 도구와 시스템을 제공하여 이메일 보안을 강화하고 있습니다.

- 이메일 암호화 솔루션을 활용하여 민감 정보 전송 시 암호화 적용.
- 스팸 필터 및 악성코드 탐지 시스템을 통한 자동 차단.
- 다단계 인증(MFA)을 통한 계정 보호 강화.
- 메일 로그 및 접근 기록 모니터링을 통한 이상 행위 탐지.
- 정기적인 보안 점검 및 취약점 분석 실시.

6. 사고 발생 시 대응 절차

이메일 관련 보안 사고 발생 시 다음 절차를 반드시 준수해야 합니다.

- 즉시 이메일 계정 비밀번호 변경 및 로그아웃 처리.
- 보안팀에 사고 사실 및 상황 상세 보고.
- 관련 이메일 및 첨부파일 보존 및 증거 확보.
- 피해 범위 및 영향 분석 지원.
- 재발 방지를 위한 추가 보안 조치 시행 및 교육 강화.

본 가이드라인은 이메일 보안 강화를 위해 전사적으로 반드시 준수되어야 하며, 관련 정책은 주기적으로 갱신될 수 있습니다. 모든 직원들은 최신 정책 내용을 숙지하고 업무에 반영해주시기 바랍니다.